

Plantilla de Reporte Ejecutivo

Presentación para Consejo / Alta Dirección

Estructura pensada para construir una presentación (PowerPoint, Keynote, etc.) a partir de los resultados de la encuesta, el IGM y el análisis de ROI.

Diapositiva 1 – Portada

- Título: “Estado de madurez GDPR – Ciberseguridad y Métricas”
- Subtítulo: “Diagnóstico [Año / Organización]”
- Datos: responsable, fecha, ámbito (organización / unidad)

Diapositiva 2 – Resumen ejecutivo

Contenido sugerido:

- IGM global (porcentaje y nivel: Reactivo/Básico/Intermedio/Avanzado/Líder).
- 3–4 mensajes clave:
- Fortalezas principales.
- Debilidades críticas.
- Riesgos asociados (regulatorios, operativos, reputacionales).
- Oportunidades de mejora con mejor ROI.

Diapositiva 3 – Metodología y fuentes

- Breve explicación de la encuesta (bloques, nº de preguntas).
- Referencia al RGPD, NIS2, ISO 27001/27701 como marcos utilizados. [web:28][web:22][web:27]
- Explicación del cálculo de IGM y del enfoque de ROI.

Diapositiva 4 – IGM global y por bloque

- Gráfico radar con puntuación por bloque:
- Gobernanza
- Riesgo/EIPD
- Medidas técnicas
- Brechas
- Terceros
- Formación
- Métricas
- Resultados regulatorios
- Innovación/IA
- Tabla breve con valores numéricos.

Diapositiva 5 – Comparativa interna / temporal

- Si hay datos históricos:
- Gráfico de barras con IGM por año.
- Si hay varias unidades:
- Gráfico de barras comparando unidades o países.

Mensaje: dónde se ha mejorado, dónde se ha retrocedido.

Diapositiva 6 – Riesgos clave y exposición

- 3–5 riesgos principales derivados de los resultados:
- p. ej. baja cobertura de EIPD, tiempos largos de parcheo, lagunas en cadena de suministro.
- Relación con posibles impactos:
- Sanciones (referencia a magnitud en UE y España). [web:3][web:6][web:11]
- Interrupción de servicio.
- Pérdida de confianza de clientes/ciudadanos.

Diapositiva 7 – Brechas e incidentes

- Número de brechas notificadas en últimos 12–36 meses.
- Tiempos medios de detección y notificación.
- Casos ilustrativos (anonimizados si procede).
- Relación con expectativas del RGPD y de las autoridades. [web:14][web:28]

Diapositiva 8 – Proveedores y cadena de suministro

- Porcentaje de proveedores con certificaciones relevantes. [web:23][web:27]
- Nivel de evaluación y monitorización continua.
- Riesgos específicos (cloud, SaaS críticos, outsourcing).

Diapositiva 9 – Cultura y comportamiento

- Nivel de formación y cobertura (% empleados formados).
- Resultados de métricas de comportamiento (phishing, reporte). [web:25]
- Mensaje: el factor humano como defensa o como vulnerabilidad.

Diapositiva 10 – Iniciativas priorizadas y ROI

- Tabla con 3–5 iniciativas clave:
- Descripción.
- Impacto esperado en IGM.
- ROI estimado y payback.
- Enfocar en “quick wins” y proyectos estructurales.

Diapositiva 11 – Hoja de ruta (12–24 meses)

- Fases:
- Corto plazo (0–6 meses): acciones urgentes y de alto impacto.
- Medio plazo (6–12 meses): proyectos de madurez.
- Largo plazo (12–24 meses): transformaciones estructurales.
- Para cada fase: objetivos, hitos, métricas de éxito.

Diapositiva 12 – Mensaje final

- Conclusión sobre el nivel de riesgo aceptable vs. real.
- Llamada a decisiones:
- Aprobación de inversiones prioritarias.
- Revisión de apetito de riesgo.
- Compromiso de seguimiento del IGM.

Notas para quien presenta

- Evitar jerga excesivamente técnica; traducir a impacto de negocio.
- No ocultar debilidades, pero contextualizarlas con plan de acción.
- Usar comparativas sectoriales cuando estén disponibles (informes ENISA, estadísticas de autoridades). [web:22][web:26][web:6][web:11]
- Mantener un equilibrio entre urgencia y viabilidad: ni complacencia, ni apocalipsis.